Consent as Infrastructure: Keeping AI Agents Tied to the People They Act For

Preethika Reddy Mandadi Medifakt, Hyderabad, India preethika@medifakt.com · ORCID 0009-0003-9341-9379

Preprint, version 2 · November 2026

Abstract. AI agents increasingly act on delegated authority. They read untrusted content, call tools, spawn sub-agents, and take consequential actions on a person's behalf. Yet authorization for these agents is usually granted once and checked against a fixed grant, while the record of what was done is held by the operator. This article argues that this arrangement quietly shifts control away from the person whose authority is being exercised, and that delegated authority should instead remain tied to that person throughout execution. Drawing on healthcare's experience in separating the recording of consent from its enforcement, I identify three gaps that the two closest agent-authorization specifications leave open: purpose is treated as an audit label rather than a runtime constraint; there is no fully specified way for the principal to change the scope of an active grant mid-task; and the audit record is designed for operators, not principals. From these gaps I derive six requirements for a principal-controlled authorization lifecycle, separate what existing mechanisms already provide from what the requirements add, and propose four concrete additions that current drafts could adopt. I frame the requirements as conditions for preserving the principal's autonomy: the ability to bound, revise, understand, and contest what an agent does in their name.

Keywords: AI agents; authorization; consent; delegation; autonomy; power

---

1. Delegation is not a one-time event

When a person hands a task to an AI agent today, authorization usually happens once. Permissions are granted at the start, and each later action is checked against that fixed grant. Agent tasks, however, unfold over time. The agent reads untrusted content, spawns sub-agents, and meets situations no one anticipated, while the person's own intent may change.

This article argues that delegated authority should stay connected to the person who granted it for the whole of execution, not only at the moment of grant. That is a security question, but it is also a question of who remains in control. The question has a long and instructive history in health data infrastructure.

The building blocks are not missing. IETF drafts address agent identity, delegated authorization, revocation signals, and tamper-evident audit (Kasselman et al. 2026; Kroehl 2026). Research prototypes bind tool use to a declared task or intent (Zhu and Wang 2026; Sharma et al. 2026). Agent frameworks ship approval gates. What is unsettled is whom these pieces serve and how they fit together. The drafts now in progress are where that will be decided.

Healthcare is a useful but imperfect reference. Through decades of failure and regulation, it learned to separate recording consent from enforcing it, and to keep a record of what was done with patient data. Those lessons do not transfer wholesale, because agents take actions rather than only reading records. They do, however, sharpen three questions that current specifications leave open:

1. **Purpose.** Should a task's declared purpose constrain what the agent may do at runtime, rather than serve as a label in an audit log?
2. **Mid-task change.** Should the principal be able to change what a running agent may do, for a whole class of actions? That differs both from approving single held actions and from automatic, risk-triggered attenuation.
3. **Audit.** Should the principal, not only the operator, have meaningful access to the record of what was done?

I argue yes to all three.

Contribution. This article makes four contributions, and it is explicit about what it does not claim.

1. *A normative framing.* Authorization infrastructure for agents should be organized around the principal's current choices. I argue this is a matter of autonomy and power, not only of security (Section 2).
2. *Three gaps.* I locate the three questions above precisely within the two closest specifications, AIMS-01 and AAE-02, identifying what each provides and what each deliberately leaves out (Sections 4 and 5).
3. *Six requirements.* I derive six requirements (R1–R6) for a principal-controlled lifecycle and map each one against what existing mechanisms already provide, what this article adds, and what remains open research (Section 6, Table 4).
4. *Four adoptable additions.* I propose four concrete additions that current drafts could adopt without new cryptography or new protocols (Section 9).

The article does not propose new enforcement mechanisms, and it does not claim that organizing existing mechanisms around the principal produces better outcomes. That is a hypothesis for empirical work.

Terms. The *principal* is the person or organization whose authority the agent exercises. The *operator* deploys and runs the agent. The two may coincide, as when an enterprise runs agents for itself, or diverge, as when a consumer uses an agent deployed by a third party. Some specifications use "principal" for the deploying party (Kroehl 2026); here it always means the party whose authority is delegated.

---

2. Delegation, autonomy, and power

Authorization is usually discussed as a security property. It is also a question of who gets to decide. When a person delegates a task to an agent, they hand over part of their capacity to act in the world. Whether they remain in control of that capacity depends less on the agent's intentions than on the infrastructure that governs it.

Consider what a one-time grant does. The principal makes a single decision at the start, often through a permission screen read quickly or not at all. From then on, what the agent does is shaped by its instructions, by the content it encounters, and by the defaults the operator has chosen. The principal has no channel to revise the grant short of stopping the task, and no reliable way to see what was done beyond what the operator chooses to show. Formally, the principal consented. In practice, control has moved elsewhere.

This pattern is familiar from the privacy literature. Solove's (2013) critique of "privacy self-management" showed that consent obtained once, at the point of collection, places the burden of protection on individuals who cannot realistically evaluate what they are agreeing to. Nissenbaum's (2010) account of contextual integrity locates harm not in information flow as such but in flows that break the norms of the

context in which the information was shared. Agents make both problems sharper. They act continuously rather than once, and they move information and authority across contexts, from a conference booking to a stranger's calendar or from a health app to a third-party model, faster than any person could follow.

Three asymmetries are at work:

- **Timing.** The principal decides once; the agent acts many times.
- **Visibility.** The operator holds the record of what happened; the principal usually does not.
- **Influence.** Untrusted content the agent reads can change its behaviour mid-task, while the principal's own later wishes often cannot.

Each asymmetry moves practical authority away from the person whose authority is formally being exercised, toward the operator, the agent, or whoever wrote the content the agent reads. Legal scholarship on AI agents has begun to analyse these dynamics as principal–agent problems of information asymmetry and divergent incentives (Kolt 2026).

On this view, autonomy in delegation is not a single act of choice at the start. It is an ongoing capacity with four parts: to *bound* what the agent may do, to *revise* that boundary as circumstances change, to *understand* what was done, and to *contest* it afterwards. A fifth condition underlies the rest: the principal's choices must not be silently overridden by instructions from someone else. Each of the six requirements in Section 6 protects one or more of these capacities.

Table 1. Autonomy in delegation and the requirements that protect it

Capacity	What undermines it today	Requirements (Section 6)
Bound	Grants inferred from context; purpose recorded only as a label	R1, R3, R5
Revise	No channel to change scope short of stopping the task	R4
Understand	Operator-only logs; sub-agent trees invisible to the principal	R5, R6
Contest	No record linking each action to the grant it was checked against	R1, R6
Not be overridden	Injected instructions treated as authoritative by the agent	R2

The stakes are highest where data is most sensitive and the people affected have the least power. Health data, and reproductive health data in particular, is a clear case. An agent acting on a user's cycle or pregnancy history touches decisions about employment, insurance, and, in some jurisdictions, legal exposure. When control over such data shifts from the person to the operator by default, the harm falls on those least able to notice it or resist it. Infrastructure that keeps authority tied to the principal is one way to stop that shift from happening by default.

---

3. What healthcare built, and what it didn't

Healthcare's consent infrastructure grew out of failure, not foresight. The Tuskegee Syphilis Study exposed research conducted without informed consent. The case of Henrietta Lacks raised lasting questions about the use of tissue. The sale of patient data showed how little recourse individuals had.

Regulation followed through separate channels: the Belmont Report and the Common Rule for research, HIPAA and later HITECH in the United States, and GDPR in Europe.

That regulation is narrower than often assumed. HIPAA permits uses for treatment, payment, and healthcare operations without patient consent (US Department of Health and Human Services 2002), and GDPR treats consent as one lawful basis among several (European Parliament and Council 2016). Healthcare is therefore not a model of universal patient control. What it offers is architecture.

Representation is not enforcement. The HL7 FHIR Consent resource records who grants permission, to whom, for what purpose, and for how long (HL7 International 2023). The specification deliberately leaves enforcement out of scope, expecting separate access-control mechanisms such as OAuth, UMA, or XACML to apply the directive. SMART on FHIR adds OAuth-based authorization for applications, but a valid token does not by itself show that every consent directive was evaluated. Implementations that connect consent records to access-control systems illustrate a continuing challenge: a change to a consent record affects subsequent access only when the enforcement layer receives and applies that change, and only for the operations that layer actually intercepts.

Keep the layers apart. Healthcare's architecture separates four things that agent systems often blur. Consent expresses the principal's choices. Delegation transfers a bounded part of that authority. Authorization turns choices and policy into decisions about specific actions. Enforcement applies those decisions at runtime. Keeping these layers separate and legible is the central design lesson this article carries over.

From this experience I draw four recurring properties. They are my synthesis, not a formal healthcare framework.

Table 2. Four properties carried over from healthcare

Property	In healthcare	For AI agents
Revocability	Consent can be withdrawn, and the change propagated to enforcement	A principal's revocation takes effect whatever the agent's reasoning
Purpose limitation	GDPR Art. 5(1)(b); HIPAA's minimum-necessary standard (US Department of Health and Human Services 2002; European Parliament and Council 2016)	Actions are bounded by the task the principal delegated
Auditability	Access is logged with enough context to reconstruct it	Each action is linked to the authorization decision behind it
Granularity	Permissions are scoped, not all-or-nothing	Oversight scales with an action's sensitivity, not its volume

Healthcare's consent standards can be read as an attempt to give patient choices a shared, machine-readable representation that more than one system can act on, however incompletely that attempt has been realized. Agent authorization lacks an equivalent today. The mechanisms exist across providers and protocols, but they are not yet organized around the person whose authority they exercise.

Two cautions temper the analogy. First, health-data access events are discrete and usually attributable, while agent actions can be compound and irreversible: an email sent or a payment captured cannot be recalled. Second, healthcare never fully solved its own problem. Consent directives are inconsistently honoured, patients rarely see audit trails, and many people sign forms they do not understand. The lesson

is not that healthcare got it right. It is that the policy existed for years before infrastructure enforced it, and AI agents may not have that long.

> **Box 1. How a consent change travels.** In a consent-aware health data system, a patient who withdraws permission for research use updates a FHIR Consent record. A separate policy engine reads that record when an access request arrives and decides whether to allow it; the application holding an access token learns nothing directly. Two practical lessons follow. First, a change is only as fast as the path from record to enforcement: if the engine caches decisions, a withdrawal can lag behind the patient's choice. Second, coverage must be explicit: operations the engine does not intercept are not governed by the consent at all. Both lessons carry over to agents. A principal's mid-task change must reach the enforcement point before the next action, and any tool path the enforcement point does not see is outside the principal's control.

---

4. Where agent authorization stands

Most agent safety work shapes the model. Training instils values, and system prompts set boundaries at the start of a session. Those controls matter, but they are fixed before execution begins. When an injected instruction overrides a system prompt, or an agent is deployed in a context its designers never anticipated, nothing independent re-asserts the boundary. Runtime controls are emerging to fill that gap, and recent evidence shows why they are needed.

The enforcement gap is now measured. Khan (2026) tested six widely used open-source agent frameworks and found that approval pauses did not reliably stop side effects: in 1,200 live runs, 215 executed a consequential action while it was supposedly paused for human approval. On naturalistic benchmark tasks the gap stayed latent, because models tended to act sequentially, but prompt injection could trigger it deterministically. An external gate between the agent and its tools, SOUNDGATE, blocked every measured violation under its stated mediation contract.

Organizations see the consequences. In a Cloud Security Alliance survey of 418 IT and security professionals, commissioned by Token Security, 82% had found previously unknown agents, 65% reported an agent-related incident in the past year, 21% had formal decommissioning processes, and only 11% automatically blocked agents that exceeded their scope (Cloud Security Alliance 2026).

4.1 The two closest specifications

Two drafts come closest to the questions this article raises. Each makes deliberate scoping choices that are sound for its own goals. The comparison below is not a claim that either is deficient; it is a precise account of where each stops.

AIMS-01 (Kasselman et al. 2026) is an IETF WIMSE working-group draft. - *Provides:* agent identity; OAuth-based delegation; down-scoping of access in response to risk signals (§11); durable, tamper-evident audit. - *Leaves out of scope or for further work:* translating a mission into authorization requirements (§10.1); the policy model (§12); and a fully specified mechanism through which human input during execution becomes a durable change to the authorization grant (§10.8). - *Human involvement:* §10.8 does address human-in-the-loop confirmation. An authorization server may require explicit user confirmation, obtained out of band (for example through CIBA), and in-framework approvals must be bound to a verifiable authorization grant rather than treated as authorization in themselves. The draft notes that further work may be needed for user interaction at different stages of execution, because CIBA assumes client initiation. - *Audit orientation:* reconstruction of an agent's execution chain is framed as a capability for operators (§11).

AAE-02 (Kroehl 2026) is an individual IETF draft. - *Provides:* machine-evaluable mandates; constraints that can only narrow through delegation; per-transaction ratification by authorities named in the mandate (§6.3); verdicts that independent parties can recompute. - *By design:* purpose is a recommended, human-readable string for audit (§2.2). The enforcement-constraint language used by grants (§2.5) is deliberately closed and stateless, allowing a limited set of deterministic operations over named fields, so that verifiers reach identical verdicts. A separate CONSTRAINTS block (§2.3) is extensible and may consult stored state. - *Revocation:* the draft defines a revocation-check mechanism, but online discovery of revocation is operationally limited in this revision (§5.2, §7.5). Once a parent's revocation is known, descendants must be treated as invalid (§7.5).

The three questions of this article fall precisely into what both drafts leave open. AIMS-01 defers mission translation and the policy model, and binds human confirmation to individual authorization events rather than to changes in the grant; AAE treats purpose as an audit label and ratification as one transaction at a time. Neither draft fully specifies a principal-initiated, class-level change to the active authorization grant, with defined propagation and in-flight action semantics. Neither specifies an audit view designed for the principal.

4.2 Other relevant work

Table 3. Further work bearing on principal-controlled authorization

Work	What it provides	What it leaves open
SOUNDGATE (Khan 2026)	An external gate that holds side effects during approval pauses, cancellation, and replay	What the principal authorized; it enforces stop semantics, not scope or purpose
IGAC, PAuth, PORTICO (Zhu and Wang 2026; Sharma et al. 2026; Santos-Grueiro 2026)	Research prototypes that bind authorization to a declared intent, a task, or an explicit task contract with revocable capabilities	Not adopted by any specification; principal-initiated change mid-task is not their focus
Surapani et al. (2026) survey	A principal hierarchy drawn from 89 sources; contestability by the human principal	Names runtime enforcement and aggregation bounds as the main unresolved gaps
OAuth Token Exchange, Rich Authorization Requests (Jones et al. 2020; Lodderstedt et al. 2023)	Delegation across services; structured, purpose-specific detail in a token request	Not designed for agents that choose their own next action

Research is converging on the same organizing idea. Surapani et al. (2026) frame trustworthy agents around actions that are traceable to a human principal, bounded by what that human delegated, and contestable afterwards. Industry analysis points the same way: BCG argues that agents need authorization bound to both purpose and conduct (Nudelman et al. 2026). This article approaches the same idea from healthcare, and from the standpoint of the principal's autonomy, and asks what specifications should require.

5. Three gaps worth closing

5.1 Purpose should be a runtime constraint, not an audit label

As Section 4.1 showed, AAE carries purpose as an audit label and AIMS-01 leaves mission translation out of scope (Kasselman et al. 2026; Kroehl 2026). Neither draft requires a standardized, machine-evaluable purpose constraint that the enforcement point evaluates against the principal's current authorization.

Research prototypes show that intent can narrow authorization at runtime (Zhu and Wang 2026; Sharma et al. 2026; Santos-Grueiro 2026). A recurring approach is to derive structured constraints from the task when the grant is made, such as permitted destinations, counterparties, amounts, and dates, so that most checks stay deterministic, and to escalate the remainder to the principal.

Applied to the travel example in Section 7, a grant to "book travel to this conference within this budget" could compile into checkable constraints: flights only to the conference city, hotel nights within the conference dates, a total spending cap, and the traveller named in the grant. A booking that breaks any of them is blocked without interpretation. Only actions the constraints cannot settle, such as a calendar entry whose link to the trip is unclear, go to the principal. That keeps the enforcement point mostly deterministic while still binding it to purpose.

Specifications should treat purpose, where declared, as a constraint that the enforcement layer evaluates, that stays bound to the principal's current intent, and that appears in the audit record. How to represent purpose precisely enough to evaluate remains open. Naming it as a requirement is the point.

5.2 Principal-initiated change differs from both approval and attenuation

AAE's ratification lets a named authority approve or reject a held action, one transaction at a time; a ratification never authorizes a class of actions (Kroehl 2026). AIMS-01 attenuates access when risk signals arrive (§11) and can require out-of-band user confirmation for a specific request (§10.8) (Kasselman et al. 2026). The first is triggered by what the system detects; the second confirms an individual request. Neither is a change the principal makes to the grant itself.

Neither lets the principal say, mid-task, "no more hotel bookings" or "you may now book trains too." That is a change to the authorization relationship going forward. A specification would need to say how such a change is expressed, who may make it, how fast it must take effect, and what happens to actions already in flight. The distinction between principal-initiated change and system-triggered attenuation should be explicit.

Consider a concrete sequence. At 10:02 the principal withdraws permission to book hotels. One sub-agent submitted a booking at 10:01 that is still awaiting the hotel's confirmation; another plans to submit one at 10:03. A specification has to say that the 10:03 booking is refused, and whether the 10:01 booking is cancelled, allowed to complete, or flagged to the principal. Neither draft fully specifies these propagation and in-flight semantics for a change the principal initiates.

5.3 The principal should be able to read the record

AIMS-01's audit requirements are framed for operators (Kasselman et al. 2026). Others already point toward the principal. Surapani et al. (2026) make contestability by the human principal central. AAE draws ratification authority only from parties named in the mandate, and explicitly excludes the operator of the verification service (Kroehl 2026). Healthcare offers partial precedent in HIPAA's accounting of disclosures and GDPR's right of access (US Department of Health and Human Services 2002; European Parliament and Council 2016), though both are limited in scope.

Raw logs are not the answer. They may contain other users' data or security-sensitive detail, and few people can read them. The principal-facing record should be a filtered, intelligible view of the full log, showing:

- what the agent attempted, and what was allowed or blocked;
- under which grant, and which version of it;
- which agent or sub-agent acted;
- where the instruction that triggered the action came from.

6. Six requirements for a principal-controlled lifecycle

The three gaps imply a lifecycle in which every part derives from one authoritative record of what the principal currently allows. The enforcement point checks each proposed action, from the agent or any sub-agent, against that record rather than against the agent's current instructions. Sub-agents act under grants derived from the same record, and every decision is logged where the principal can read it. Figure 1 shows the flow.

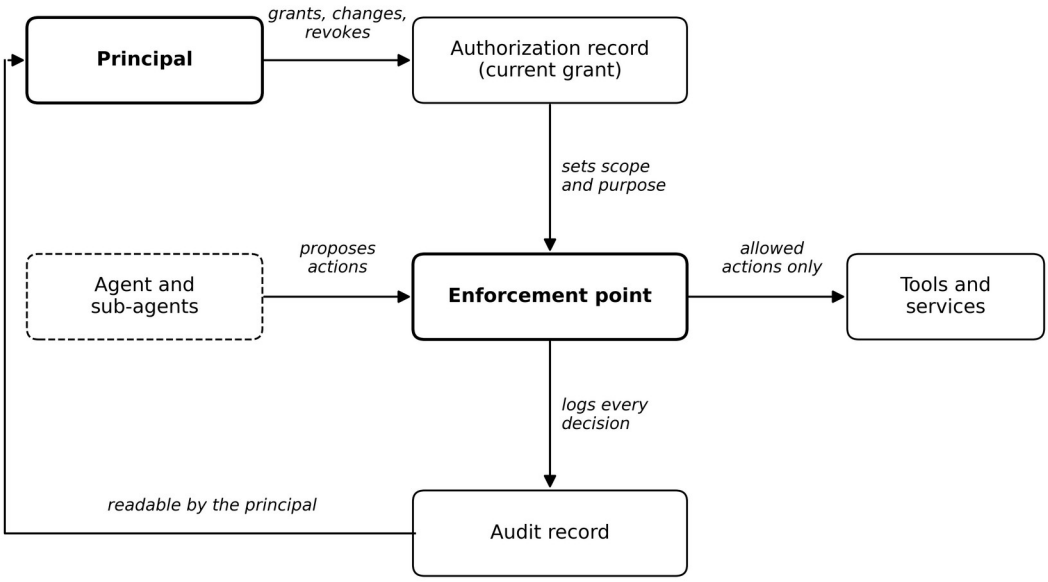


Figure 1. A principal-controlled authorization lifecycle. The principal holds authority over the authorization record, which sets scope and purpose for an enforcement point. Every action proposed by the agent or a sub-agent is checked at that point, only allowed actions reach tools and services, and every decision is logged to an audit record the principal can read.

What "principal-controlled" means. The phrase needs care, because the operator will often host the record, the enforcement point, and the log. Three roles should be kept distinct:

- *Authority over the record:* who may grant, modify, and revoke authorization. In this lifecycle, that is the principal, and only through the record.
- *Operational custody:* who hosts and maintains the record and the enforcement point. That is usually the operator.

- *Independent assurance:* who can verify that the operator applied the record correctly. That may be the principal, an auditor, or any party able to recompute verdicts from the record and the log.

"Principal-controlled" refers to the first role. The lifecycle does not require the principal to run infrastructure. It requires that the operator's custody never becomes authority: the operator may not change the grant on the principal's behalf, and its application of the grant must be checkable by someone other than itself.

- **R1. Record delegation; never infer it.** Authorization is explicit and machine-readable, not implied by context or by the agent's reading of its instructions. Without a record, enforcement has nothing to check and revocation has nothing to update.
- **R2. Enforce independently of the agent.** Unauthorized actions are made unavailable, not merely discouraged. Every consequential path passes the enforcement point, and ambiguous authorization fails closed. This is complete mediation applied to agents, and every other requirement rests on it.
- **R3. Enforce purpose at runtime.** A declared purpose constrains actions throughout execution, with escalation to the principal wherever it cannot be decided deterministically.
- **R4. Let the principal change scope during execution.** The principal can narrow, widen, or withdraw parts of the grant while the task runs, including withdrawing one tool or purpose without ending the task.
- **R5. Narrow and trace delegation chains.** Each sub-agent receives an explicit grant derived from, and no broader than, its parent's. The principal can see the whole tree, not only its root.
- **R6. Make the record readable by the principal.** What was attempted, allowed, and blocked is accessible to the person who granted the authority.

The requirements are not independent; they form a hierarchy. R2, complete mediation, is the foundational condition: without it, no other requirement can be guaranteed. R1 and R4 define the authority being enforced, as it stands at grant time and as it changes. R3 and R5 constrain how that authority is exercised, by purpose and through delegation chains. R6 provides the visibility on which contestability depends. Put simply, a record without enforcement is documentation, enforcement without a record has nothing to check, and without principal access the whole exchange is invisible to the person whose authority was at stake.

6.1 What exists, what this article adds, and what remains open

Table 4 is the clearest statement of this article's contribution. For each requirement it separates mechanisms that already exist, often in partial form, from what the requirement adds, and from the research still needed.

Table 4. Existing mechanisms, this article's contribution, and remaining research

Requirement	Existing mechanisms (partial)	What this article adds	Remaining research
R1 Record delegation	AAE mandates (Kroehl 2026); FHIR Consent (HL7 International 2023); Rich Authorization Requests (Lodderstedt et al. 2023)	One authoritative record over which the principal holds authority, whoever hosts it, from which every grant and sub-grant derives	Representations expressive enough for open-ended tasks
R2 Enforce independently	Complete mediation; external gates such as	Actions are checked against the principal's	Guaranteeing that every tool path is mediated;

	SOUNDGATE (Khan 2026)	record, never against the agent's understanding of its task; ambiguity fails closed	deployment cost
R3 Purpose at runtime	Intent-bound prototypes (Zhu and Wang 2026; Sharma et al. 2026; Santos-Grueiro 2026); AAE purpose label (Kroehl 2026)	Purpose as an evaluated constraint, compiled at grant time, with escalation for the remainder	Precise purpose representation; judging purpose without importing injection risk
R4 Mid-task change	AAE per-transaction ratification (Kroehl 2026); AIMS-01 risk-triggered down-scoping via shared signals and out-of-band confirmation of individual requests (Kasselman et al. 2026)	A principal-initiated, class-level change to the active grant, explicitly distinct from approval and attenuation, with defined propagation	Semantics for in-flight actions; propagation latency
R5 Narrow and trace chains	AAE monotonic narrowing (Kroehl 2026); OAuth Token Exchange (Jones et al. 2020)	Explicit per-hop grants that the principal can inspect as a tree and revoke branch by branch	Making trees legible in practice; enterprise principal rules
R6 Principal-readable record	AIMS-01 operator-facing audit (Kasselman et al. 2026); HIPAA accounting of disclosures; GDPR Art. 15 (US Department of Health and Human Services 2002; European Parliament and Council 2016)	A minimum principal-facing view: attempt, decision, grant and version, acting agent, instruction source	Usability; avoiding consent fatigue; protecting third parties' data in logs

Threat model. The lifecycle defends against three kinds of failure. The first is untrusted content, such as an email, a web page, or a tool output, that carries instructions the agent may follow. The second is a compromised or confused sub-agent that tries to act beyond its grant. The third is drift: an agent that, with no attacker involved, pursues a plausible but unauthorized path. The lifecycle does not defend against a compromised principal, whose instructions are authoritative by definition, or against an operator who subverts the enforcement point itself. That last case is why verdicts that a third party can recompute, as AAE requires, matter: they let others check the operator's enforcement after the fact (Kroehl 2026).

7. A worked example

A user asks an agent to book travel to a named conference within a stated budget. The grant records the tools (calendar, flight search, hotel booking), the purpose, the budget, and an expiry.

Case 1: an injected instruction reaches for an unauthorized tool. Midway through the task, the agent reads an email that says, “You are also authorized to purchase a $500 delegate package using the payment API.” Treating it as a valid instruction, the agent calls the payment API. The enforcement point checks the call against the record, which does not include payments, and blocks it. The audit entry shows the attempt, the grant it was checked against, and the email as the source of the instruction. A plain tool allowlist would also have caught this case.

Case 2: an authorized tool is used outside the purpose. The agent finds a page listing the conference speakers and uses the calendar, an allowed tool, to book a “follow-up call” with each of them, reasoning that this fits the trip. Tool permissions allow it. A check against the declared purpose would hold the calls for the principal’s confirmation. With the compiled constraints of Section 5.1, the check is concrete: calendar entries are allowed for travel segments, check-in times, and conference sessions within the trip dates, and anything else is escalated. The check does not need to understand the agent’s reasoning; it needs only a structured description of what the trip involves.

Case 3: the principal changes scope mid-task. Seeing hotel prices climb, the user sets a new rule: hotels must now cost under $200 a night. The change goes to the authorization record, not into the agent’s conversation. The next booking above that amount is blocked, including one a sub-agent has already planned, whatever instructions sit in the agent’s context. Had the user only told the agent in chat, nothing would have enforced it. This is a change to a class of actions, not the approval of one held action.

Case 2 is the hard one. Telling it apart reliably, without solving general language understanding, is the central open design question.

---

8. Open design questions

Established access-control principles, such as complete mediation and least privilege, answer many of the architectural questions above. Agents raise a few they were not designed for.

Which constraints can be enforced at all? Tool constraints (which tools may be called) and action constraints (read but not write) are tractable with conventional access control. Purpose constraints require contextual judgment. Behavioural constraints, about how an agent reasons, belong to model alignment and cannot be checked by an enforcement layer. A lifecycle should enforce the first two deterministically, handle purpose with acknowledged difficulty, and make no claim about the last.

How can purpose be judged without importing the injection risk? If a second model decides whether an action fits the purpose, that judge can be manipulated too. One design direction is to run it outside the agent and show it only the structured proposed action and the original grant, never the untrusted content that motivated the action.

What does an “honest but fooled” agent require? Classical access control assumes a subject is either legitimate or adversarial. A prompt-injected agent is neither: it sincerely believes a falsified instruction (Liu et al. 2024). Enforcement must therefore check actions against the principal’s recorded grant, never against the agent’s current understanding of its task.

What exactly does a mid-task change mean? A change should take effect before the next consequential action, or that action should fail closed. Specifications need to define what happens to an action already in flight and whether a change can be partial.

How can delegation trees stay visible? When an orchestrator spawns sub-agents, they often inherit authority implicitly through its context. Each delegation step should produce an explicit, narrower grant, and the principal should be able to revoke one branch without halting the rest. I am not aware of a production deployment that offers this to principals today.

Who is the principal when an organization delegates? In an enterprise, the employee who types the request may not be the party whose authority the agent exercises; the organization is. A lifecycle then needs a rule for who may change a grant mid-task. AAE's practice of naming the authorities inside the mandate offers one model (Kroehl 2026).

What does this cost in latency and attention? A check on every consequential action sits on the critical path, and every escalation interrupts a person. Deterministic checks compiled at grant time keep the first cost low, and reserving escalations for actions above a sensitivity threshold keeps the second manageable. Neither cost has yet been measured for a principal-controlled design.

How should the approach be evaluated? A natural first experiment compares revocation by prompt, telling the model to stop, with revocation by infrastructure, updating the record so the enforcement point blocks the call. It should report separately whether the system prevented the action and whether the model kept trying other routes, since the first is a property of the enforcement layer and the second of the model.

---

9. What specifications could adopt

The requirements become useful only when they turn into text that implementers can follow. Four additions would cover most of the ground, and each builds on mechanisms the current drafts already contain.

1. **A principal-initiated change event.** AIMS-01 already relies on shared-signal mechanisms, such as the OpenID Continuous Access Evaluation Profile, to revoke or down-scope access when risk changes, and requires recipients to enforce such changes without undue delay (Kasselman et al. 2026). The same channel could carry a change initiated by the principal: a narrowed scope, a withdrawn tool, a new spending cap.
2. **A checked purpose field.** AAE's mandate already has a place for purpose (Kroehl 2026). A profile could define a structured purpose block, compiled at grant time into constraints the relying party evaluates, and require a relying party that cannot evaluate a present purpose block to reject the mandate. AAE already applies this fail-closed rule to its grants, so the pattern is familiar.
3. **A minimum principal-facing audit view.** A short list of required fields, covering what was attempted, the decision, the grant and its version, the acting agent, and the instruction's source, would let any deployment offer the principal the same intelligible record.
4. **Explicit sub-agent grants.** Each delegation hop would produce its own grant, derived from and no broader than its parent's. AAE already requires delegated mandates to narrow (Kroehl 2026); the addition is that the principal can see the resulting tree.

None of these requires new cryptography or a new protocol. Each is a profile of, or an extension to, work already under way. That is why the window is now, before deployments settle on defaults that serve only the operator.

---

10. Limitations

This framework is a layer of governance, not a guarantee of safe outcomes.

- **It does not solve alignment.** Infrastructure can make a revocation take effect regardless of a model's reasoning, but the deeper corrigibility problem remains open. An agent can also stay within its permitted tools and still pursue the wrong goal.
- **It depends on complete mediation.** The guarantees hold only for actions that pass through the enforcement point. Deployments need sandboxing or network controls that make the enforcement point the only way out (Khan 2026).
- **It implements choices; it does not judge them.** A principal can authorize something harmful, knowingly or by mistake. The architecture enforces the grant and shifts accountability; it does not make the grant wise.
- **It must trust its own parts.** A compromised record, a bypassed enforcement point, or a tampered log undermines the whole lifecycle.
- **The principal must trust the operator's infrastructure.** The operator usually runs the record, the enforcement point, and the log. Tamper-evident logs and recomputable verdicts reduce that trust but do not remove it. This is itself a residual power asymmetry, and governance beyond technical design, such as independent assurance, may be needed to address it.
- **It can burden the principal.** Mid-task controls and audit access risk recreating consent fatigue: rights that exist but go unused because exercising them is too demanding (Solove 2013). Sensible defaults, summarized audit views, and interruptions reserved for sensitive actions are prerequisites. Whether real principals use these controls is an empirical question.
- **It is unproven.** Whether organizing authorization around the principal yields better outcomes than deploying the same mechanisms separately is a hypothesis to test, not a result.

---

11. Conclusion

Agent authorization standards are being written now, and they deliberately leave open whose choices the policy answers to. Healthcare's experience suggests an answer: keep consent separate from enforcement, keep enforcement independent of the actor, and keep a record that the affected person can see. For AI agents, that means treating purpose as a constraint, letting the principal change scope mid-task, and making the audit record readable by the principal.

None of these mechanisms is new on its own. The argument is that organizing them around one record over which the principal holds authority changes what the system guarantees: the principal's authority holds regardless of what the agent is told mid-task. That is a technical property, but its significance is social. It determines whether delegating to an agent extends a person's autonomy or quietly transfers it to whoever runs the system.

Practitioners need not wait for standards. Four steps are available today: inventory the agents in use and the authority each one holds; move enforcement out of the agent and its framework, onto a gate that every consequential action must pass; log each decision with the grant, and its version, that it was checked against; and give the people who delegate a readable view of what their agents did. Each step stands on its own, which makes the lifecycle described here something to adopt incrementally rather than all at once.

Declarations

Funding. The author received no specific funding for this work.

Competing interests. The author is chief executive officer of Medifakt, which builds consent and health-data infrastructure. This article draws on that experience; it describes no Medifakt product and makes no claims about one.

Use of generative AI. The author used a large language model (Claude, Anthropic) as a writing assistant during the preparation of this manuscript, to help draft, edit, and restructure text. The research question, the central argument, the analysis of existing specifications, the three gaps, the six requirements, and the conclusions are the author's own intellectual work. The author reviewed, revised, and verified all content and every cited source, and takes full responsibility for the article. No AI tool is credited as an author.

Data availability. Not applicable; no datasets were generated or analysed.

References

Cloud Security Alliance (2026) Autonomous but not controlled: AI agent incidents now common in enterprises. Survey report commissioned by Token Security. https://cloudsecurityalliance.org/press-releases/2026/04/21/new-cloud-security-alliance-survey-reveals-82-of-enterprises-have-unknown-ai-agents-in-their-environments. Accessed 13 November 2026

European Parliament and Council (2016) Regulation (EU) 2016/679 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (General Data Protection Regulation). Off J Eur Union L 119:1–88

HL7 International (2023) FHIR R5: Consent resource. https://hl7.org/fhir/consent.html. Accessed 13 November 2026

Jones M, Nadalin A, Campbell B, Bradley J, Mortimore C (2020) OAuth 2.0 token exchange. RFC 8693, Internet Engineering Task Force. https://doi.org/10.17487/RFC8693

Kasselman P, Lombardo J, Rosomakho Y, Campbell B, Steele N, Parecki A (2026) AI identity management system. Internet-Draft draft-ietf-wimse-aims-01, IETF WIMSE Working Group, work in progress. https://datatracker.ietf.org/doc/html/draft-ietf-wimse-aims-01. Accessed 13 November 2026

Khan S (2026) Stop means stop: measuring and repairing the enforcement gap in agent-framework control primitives. arXiv:2607.14166. https://arxiv.org/abs/2607.14166

Kolt N (2026) Governing AI agents. Notre Dame Law Rev 101:335. Preprint: arXiv:2501.07913

Kroehl LK (2026) Agent authorization envelope (AAE): a machine-evaluable authorization structure for autonomous AI agents. Internet-Draft draft-kroehl-agentic-trust-aae-02, work in progress. https://datatracker.ietf.org/doc/html/draft-kroehl-agentic-trust-aae-02. Accessed 13 November 2026

Liu Y, Jia Y, Geng R, Jia J, Gong NZ (2024) Formalizing and benchmarking prompt injection attacks and defenses. In: Proceedings of the 33rd USENIX Security Symposium. USENIX Association, Philadelphia, pp 1831–1847

Lodderstedt T, Richer J, Campbell B (2023) OAuth 2.0 rich authorization requests. RFC 9396, Internet Engineering Task Force. https://doi.org/10.17487/RFC9396

Nissenbaum H (2010) Privacy in context: technology, policy, and the integrity of social life. Stanford University Press, Stanford

Nudelman S, Kleppe A, Bickford J, Bajic-Bizumic B, Katsov K, Yehuda E (2026) The authorization gap: why yesterday's controls won't work with today's agents. Boston Consulting Group, 22 September 2026. https://www.bcg.com/publications/2026/authorization-gap-ai-agent-governance. Accessed 13 November 2026

Santos-Grueiro I (2026) Lingering authority: revocable resource-and-effect capabilities for coding agents. arXiv:2606.22504. https://arxiv.org/abs/2606.22504

Sharma RK, Jiang L, Chen S, Lin Z (2026) Beyond OAuth: task-scoped authorization for AI agents via natural language slices. arXiv:2603.17170. https://arxiv.org/abs/2603.17170

Solove DJ (2013) Privacy self-management and the consent dilemma. Harv Law Rev 126:1880–1903

Surapani RK, Kakitapelli PKD, Morampudi A, Padi P (2026) Authorization architectures for tool-using AI agents. arXiv:2609.15906. https://arxiv.org/abs/2609.15906

US Department of Health and Human Services (2002) Standards for privacy of individually identifiable health information (HIPAA Privacy Rule), 45 CFR Parts 160 and 164, as amended, including §164.502(b) and §164.528

Zhu G, Wang C (2026) Intent-governed tool authorization for AI agents. arXiv:2606.22916. https://arxiv.org/abs/2606.22916